

# DigiT — Platform-Aware Device Authentication

One device on Android / Windows, many devices on Apple — using passkeys as designed · v1.0

DigiT allows a customer **one device on Android or Windows**, but **multiple devices on Apple** (thanks to Apple's secure cross-device synchronisation). This is not a workaround — it maps exactly onto a real distinction in modern passwordless auth: **passkeys (WebAuthn / FIDO2)** come in two kinds, **synced** and **device-bound**. This document extends the Secure Onboarding spec with the platform-aware device layer.

**The mechanism, in one line:** a **synced passkey** is backed up and copied across a user's devices by the platform's credential manager (Apple's iCloud Keychain); a **device-bound passkey** is locked in one device's secure hardware and can never leave it. Apple → synced → many devices. Android / Windows → device-bound → one device.

## 1 The two tracks

Two tracks — one passkey, two behaviours



Figure 1 — One passkey, two behaviours: Apple's syncs securely to every Apple device the user owns; Android / Windows stays on the single device it was created on.

- **Apple → synced passkey → multiple devices** — DigiT registers *one* passkey; iCloud Keychain propagates it to the user's iPhone, iPad and Mac — end-to-end encrypted, protected by the Secure Enclave and their Apple ID + Face / Touch ID. You never register each device; Apple's sync does it, securely.
- **Android / Windows → device-bound passkey → single device** — the private key is pinned to that device's secure hardware (Keystore / StrongBox on Android, TPM on Windows) and cannot roam. One device, full stop.

## 2 How DigiT decides the track

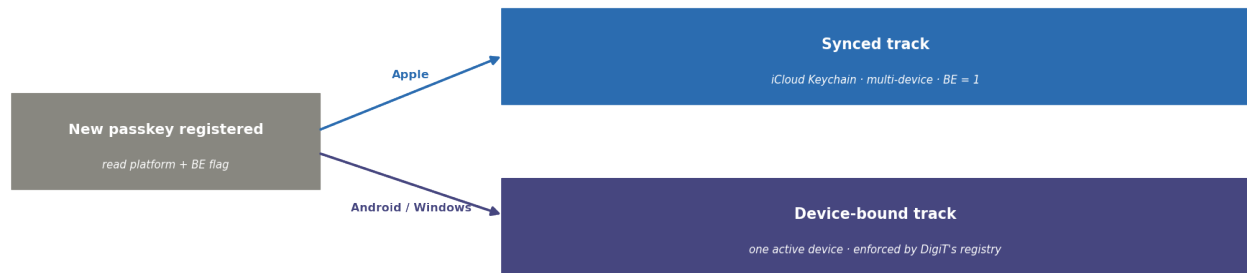


Figure 2 — At registration, the platform and the passkey's own flags decide the track.

The WebAuthn response carries two flags in the authenticator data: **BE (Backup Eligible)** — can this credential sync? (1 = synced, 0 = device-bound) — and **BS (Backup State)** — is it currently synced? DigiT reads these plus the platform (via user-agent / client hints) and assigns the track.

**Important — single-device on Android is *your* policy, not a limitation.** Android *can* also sync passkeys (via Google Password Manager, also end-to-end encrypted). So “one device on Android” is a rule **DigiT enforces on the server** — the same “the server is the wall, not the client” principle from your limits design. What guarantees it is the device registry below, not the operating system.

### 3 The device registry — where the rule is enforced

DigiT keeps one row per registered credential. The **invariant**: for the Android / Windows track, **at most one active device credential per user**, checked on every sign-in. Apple's synced credential is treated as one identity valid across the user's Apple devices — because a synced passkey presents the *same credential\_id* everywhere, DigiT simply sees its one registered credential being used and trusts Apple's sync.

| Field         | Meaning                                                          |
|---------------|------------------------------------------------------------------|
| credential_id | the passkey's unique id (same everywhere for a synced Apple key) |
| user_id       | who it belongs to                                                |
| platform      | apple / android / windows                                        |
| type          | synced or device-bound (from the BE flag)                        |
| device_label  | a friendly name (“Pixel 8”, “Work laptop”)                       |
| status        | active / revoked                                                 |
| last_seen     | last successful sign-in                                          |

## 4 Moving to a new Android / Windows device

Since only one non-Apple device can be active, moving is an explicit, secure switch — reusing your one-time passcode enrollment.

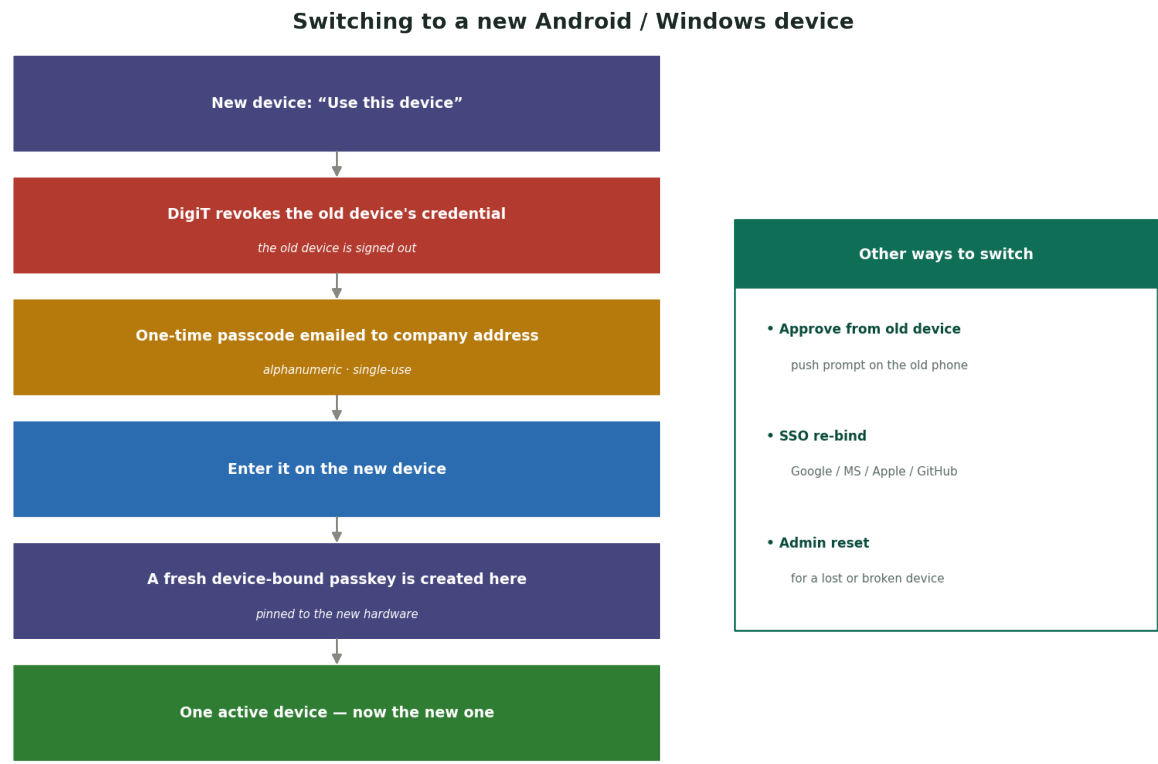


Figure 3 — The device-switch flow, with lower-friction alternatives on the right.

1. On the new device, the user starts “Use this device.”
2. DigiT **revokes the old device's credential** — the old device is signed out.
3. A **one-time alphanumeric passcode** is emailed to their company address.
4. They enter it on the new device.
5. A **fresh device-bound passkey** is created and pinned to the new hardware.
6. One active device again — now the new one.

Lower-friction alternatives: **approve-from-old-device** (a push prompt to the old phone authorises the new one, no email round-trip), **SSO re-bind** (sign in via Google / Microsoft / Apple / GitHub, which becomes the new active device), or **admin reset** for a lost device.

## 5 Signing in, once set up

| Device                                      | Passkey present?                 | Result                             |
|---------------------------------------------|----------------------------------|------------------------------------|
| Any of the user's Apple devices             | Yes — synced via iCloud Keychain | Biometric → in                     |
| The one registered Android / Windows device | Yes — device-bound               | Biometric → in                     |
| An unregistered Android / Windows device    | No credential exists             | Device-switch flow, or SSO re-bind |

The unregistered-device case is exactly the “new device is a dead-end unless you re-bind” behaviour from your onboarding spec — now made platform-aware.

## 6 Why it is secure on both sides

- **Apple multi-device does not lower the bar** — the key is still hardware-protected on each device, and the sync is end-to-end encrypted and gated by Apple ID + biometrics. You are extending trust across *the same user's* secure devices.
  - **Android / Windows single-device is the tightest possible** — the key cannot leave the secure hardware, and even if the OS would sync it, DigiT's server only ever lets one device be active — so a second device is inert until a verified switch.
- 

## 7 Edge cases & how it fits

- **A user with both ecosystems** — someone with, say, an iPhone and a Windows laptop has their synced Apple credential *plus* one active non-Apple device. The two tracks coexist per-user — usually what you want, but set it consciously as a policy knob.
- **Fits your existing auth spec** — this is the platform-aware device layer on top of the Secure Onboarding design: the one-time passcode enrollment, the device-bound model, and the SSO fallback are all reused — now split into a synced track and a device-bound track by platform.

Note: passkey and sync behaviours evolve with OS versions; treat the BE / BS flags as the source of truth at registration, and keep the server-side registry as the ultimate enforcer.